

---

## Informe Profesional de Pentesting

### Actividad A08 — Hacking Ético

Cliente: INSECUR S.A. — Laboratorio: TryHackMe

---

Seguridad Aplicada a Sistemas de Información  
Licenciatura en Sistemas de Información — Facultad de Informática y Diseño  
Docente: Ing. Rodrigo Atilio Elgueta  
Contratista: **Exequiel Caliri** — Username THM: **exequielcaliri686**  
Ciclo Académico Vigente

## Índice

|          |                                                     |          |
|----------|-----------------------------------------------------|----------|
| <b>1</b> | <b>Contexto de la Contratación</b>                  | <b>2</b> |
| <b>2</b> | <b>Modelo de Trabajo: Núcleo + Sala de Elección</b> | <b>2</b> |
| 2.1      | Nivel 1 — Núcleo obligatorio . . . . .              | 2        |
| 2.2      | Nivel 2 — Sala de elección . . . . .                | 2        |
| <b>3</b> | <b>PARTE II: INFORME DE PENTESTING</b>              | <b>3</b> |
| 3.1      | Datos generales . . . . .                           | 3        |
| 3.2      | Pre-pentesting . . . . .                            | 3        |
| 3.3      | Durante: Hallazgos por fase . . . . .               | 4        |
| 3.4      | Resumen ejecutivo de hallazgos . . . . .            | 7        |
| 3.5      | Post-pentesting: Recomendaciones . . . . .          | 7        |
| <b>4</b> | <b>PARTE III: PROTOCOLO DE CONTINGENCIA</b>         | <b>8</b> |
| <b>5</b> | <b>Anexos</b>                                       | <b>9</b> |
| <b>6</b> | <b>Fuentes y bibliografía</b>                       | <b>9</b> |

## 1. Contexto de la Contratación

### Carta de Autorización — INSECUR S.A.

**Cliente:** INSECUR S.A.

**Contratista:** Exequiel Caliri — Estudiante de Seguridad Aplicada a Sistemas de Información (FID-UCH).

**Objeto del contrato:** La compañía INSECUR S.A., preocupada por los niveles de seguridad de sus sistemas, contrata sus servicios profesionales de **Hacking Ético** para elaborar un plan de seguridad y contingencia.

**Alcance autorizado:** Únicamente los entornos de laboratorio de la plataforma **TryHackMe** asignados en la guía de la actividad. Cualquier acción fuera de este alcance queda estrictamente prohibida y constituye un delito conforme la legislación vigente.

**Entregable:** Informe profesional de pentesting, incluyendo documentación previa, durante y posterior a la intervención, más un protocolo de contingencia para garantizar la continuidad de negocio.

**Modalidad:** Individual.

**Repositorio de entrega:** [https://github.com/UCHSeguridad2026/TP\\_THM.git](https://github.com/UCHSeguridad2026/TP_THM.git) (branch caliri-exequiel).

### Ética y Legalidad

Esta actividad se desarrolla en **entornos controlados (sandbox)**. Queda absolutamente prohibido aplicar las técnicas aprendidas contra sistemas reales sin autorización escrita. El incumplimiento será considerado falta ética grave y podrá derivar en sanciones académicas y legales.

## 2. Modelo de Trabajo: Núcleo + Sala de Elección

La actividad se estructura en dos niveles que garantizan una base común y, al mismo tiempo, diversidad en los casos trabajados.

### 2.1. Nivel 1 — Núcleo obligatorio

#### Núcleo Obligatorio

##### 1. Pentesting Fundamentals

<https://tryhackme.com/room/pentestingfundamentals>

*Metodología y fases del pentesting profesional.*

##### 2. Basic Pentesting

<https://tryhackme.com/room/basicpentestingjt>

*Aplicación práctica completa: enumeración, explotación y escalada de privilegios.*

### 2.2. Nivel 2 — Sala de elección

Sala elegida: **Kenobi** (<https://tryhackme.com/room/kenobi>). Enfoque Samba + escalada de privilegios en Linux. Se justifica esta elección porque el trabajo realizado sobre la máquina asignada combinó enumeración de recursos Samba, acceso por SSH y post-explotación orientada a escalada de privilegios en Linux (Sección 3.2).

### 3. PARTE II: INFORME DE PENTESTING

#### 3.1. Datos generales

| Campo                      | Valor                       |
|----------------------------|-----------------------------|
| Cliente                    | INSECUR S.A.                |
| Contratista (alumno/a)     | Exequiel Caliri             |
| DNI                        | 44.058.433                  |
| Username TryHackMe         | exequielcaliri686           |
| Email institucional        | exequielcaliri686@gmail.com |
| Sala de elección (Nivel 2) | Kenobi                      |
| Branch en GitHub           | caliri-exequiel             |
| Fecha de inicio            | 07/10/2026                  |
| Fecha de cierre            | 08/10/2026                  |

#### 3.2. Pre-pentesting

##### Alcance del trabajo

**Dentro del alcance:** exclusivamente la máquina virtual asignada en la plataforma TryHackMe, accedida a través de la VPN oficial de THM (Basic Pentesting / Kenobi — Núcleo + Nivel 2). La IP asignada por THM varió entre sesiones debido a la renovación periódica de la instancia por parte de la plataforma.

**Fuera del alcance:** toda infraestructura real de INSECUR S.A., cualquier sistema de terceros, la propia plataforma TryHackMe y la infraestructura de red de la facultad. No se realizaron ataques de denegación de servicio ni pruebas destructivas.

##### Reglas de Enfrentamiento (ROE)

- Las pruebas se ejecutaron únicamente contra la IP asignada dinámicamente por TryHackMe, y solo mientras la máquina estuvo desplegada para el estudiante.
- Se trabajó sobre un entorno de laboratorio aislado; no se accedió a datos reales ni personales.
- No se instaló persistencia ni puertas traseras.
- Las credenciales obtenidas se trataron como material sensible: no se incluyen en texto plano en el repositorio, solo se documenta la evidencia de su compromiso.

##### Autorización

Declaro contar con autorización expresa de la cátedra de Seguridad Aplicada a Sistemas de Información (FID-UCH) para realizar las pruebas de intrusión sobre los entornos de laboratorio de TryHackMe indicados en el alcance. Todas las actividades las desarrollé con fines exclusivamente académicos, dentro de dichos entornos controlados.

**Metodología utilizada**

Se adoptó una metodología basada en **PTES (Penetration Testing Execution Standard)**, complementada con **NIST SP 800-115** para el rigor técnico y la trazabilidad de la evidencia.

**Justificación:** PTES ofrece un marco de fases claro y ampliamente adoptado (pre-engagement, reconocimiento, escaneo, explotación, post-explotación y reporte) que se alinea con el flujo pedagógico de la actividad. NIST SP 800-115 aporta rigor técnico adicional para la documentación de la evidencia recolectada.

**3.3. Durante: Hallazgos por fase**

A continuación se documenta cada hallazgo relevante identificado sobre la máquina objetivo.

| <b>Campo</b>                  |               | <b>Valor</b>                                                                                                                                                                                                                           |
|-------------------------------|---------------|----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| ID del hallazgo               |               | H-01                                                                                                                                                                                                                                   |
| Fase                          |               | <input checked="" type="checkbox"/> Escaneo                                                                                                                                                                                            |
| Descripción                   |               | El escaneo con Nmap reveló una superficie de ataque considerable: servicios SSH (22), HTTP (80), SMB/NetBIOS (139/445), AJP13 (8009) y un proxy HTTP alternativo (8080) expuestos simultáneamente.                                     |
| Componente                    | afectado      | Configuración de servicios y exposición de puertos.                                                                                                                                                                                    |
| Categoría                     | (OWASP / CWE) | OWASP A05:2021 (Security Misconfiguration); CWE-200 (Exposure of Information).                                                                                                                                                         |
| CVE (si aplica)               |               | No aplica directamente.                                                                                                                                                                                                                |
| CVSS estimado                 |               | <input checked="" type="checkbox"/> Bajo                                                                                                                                                                                               |
| Evidencia (captura / comando) |               | <code>nmap</code> contra la IP asignada por THM; salida completa en <code>bitacora/</code> .                                                                                                                                           |
| Herramienta                   | utilizada     | nmap.                                                                                                                                                                                                                                  |
| Impacto en la Tríada CIA      |               | <input checked="" type="checkbox"/> Confidencialidad                                                                                                                                                                                   |
| Salvaguarda                   | propuesta     | Reducir la superficie de ataque cerrando/deshabilitando servicios innecesarios (en especial AJP13, poco frecuente y asociado a vulnerabilidades conocidas como Ghostcat), y exponer únicamente los servicios estrictamente necesarios. |
| Riesgo residual tras aplicar  |               | <input checked="" type="checkbox"/> Bajo                                                                                                                                                                                               |

| Campo                         |       | Valor                                                                                                                                                                                                                             |
|-------------------------------|-------|-----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| ID del hallazgo               |       | H-02                                                                                                                                                                                                                              |
| Fase                          |       | <input checked="" type="checkbox"/> Enumeración                                                                                                                                                                                   |
| Descripción                   |       | El servicio Samba (puertos 139/445) permitía enumeración de los recursos compartidos, revelando los nombres de usuario del sistema ( <b>jan</b> y <b>kay</b> ), información clave utilizada en los ataques posteriores sobre SSH. |
| Componente afectado           | afec- | Servicio Samba/SMB.                                                                                                                                                                                                               |
| Categoría (OWASP / CWE)       |       | CWE-200 (Exposure of Sensitive Information to an Unauthorized Actor).                                                                                                                                                             |
| CVE (si aplica)               |       | No aplica (configuración).                                                                                                                                                                                                        |
| CVSS estimado                 |       | <input checked="" type="checkbox"/> Medio                                                                                                                                                                                         |
| Evidencia (captura / comando) |       | Enumeración de recursos Samba; evidencia en <b>evidencias/escaneo/</b> .                                                                                                                                                          |
| Herramienta utilizada         | uti-  | smbclient / enum4linux.                                                                                                                                                                                                           |
| Impacto en la Tríada CIA      |       | <input checked="" type="checkbox"/> Confidencialidad                                                                                                                                                                              |
| Salvaguarda propuesta         | prop- | Deshabilitar sesiones nulas y listados anónimos en Samba ( <b>restrict anonymous</b> ), limitar el acceso a los recursos compartidos y exponer SMB solo a redes internas confiables.                                              |
| Riesgo residual tras aplicar  |       | <input checked="" type="checkbox"/> Bajo                                                                                                                                                                                          |

| Campo               |       | Valor                                                                                                                                                                                                                                                                                                                                             |
|---------------------|-------|---------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| ID del hallazgo     |       | H-03                                                                                                                                                                                                                                                                                                                                              |
| Fase                |       | <input checked="" type="checkbox"/> Explotación                                                                                                                                                                                                                                                                                                   |
| Descripción         |       | Se obtuvo acceso remoto válido por SSH como el usuario <b>kay</b> , a partir de las credenciales expuestas/recuperadas durante la fase de enumeración. <i>(Pendiente: completar en esta fila el método exacto de obtención de la contraseña — archivo expuesto, fuerza bruta con diccionario, u otro — junto con la captura correspondiente.)</i> |
| Componente afectado | afec- | Servicio SSH (puerto 22) / cuenta de usuario <b>kay</b> .                                                                                                                                                                                                                                                                                         |

| Categoría (OWASP / CWE)       | CWE-521 (Weak Password Requirements) / CWE-522 (Insufficiently Protected Credentials), a confirmar según el vector exacto.                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                      |
|-------------------------------|-------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| CVE (si aplica)               | No aplica (mala configuración / política de credenciales).                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                      |
| CVSS estimado                 | <input checked="" type="checkbox"/> Alto                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                        |
| Evidencia (captura / comando) | Sesión SSH como <code>kay</code> : <code>whoami</code> , <code>id</code> . Evidencia en <code>evidencias/explotacion/</code> .                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                  |
| Herramienta utilizada         | ssh (y la herramienta de obtención de credenciales a confirmar).                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                |
| Impacto en la Tríada CIA      | <input checked="" type="checkbox"/> Confidencialidad <input checked="" type="checkbox"/> Integridad                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                             |
| Salvaguarda propuesta         | Imponer política de contraseñas robustas, deshabilitar autenticación por contraseña en SSH (usar claves), y aplicar <code>fail2ban</code> para bloquear intentos de fuerza bruta.                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                               |
| Riesgo residual tras aplicar  | <input checked="" type="checkbox"/> Bajo                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                        |
| Campo                         | Valor                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                           |
| ID del hallazgo               | H-04                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                            |
| Fase                          | <input checked="" type="checkbox"/> Post-explotación                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                            |
| Descripción                   | Durante la enumeración de privilegios como <code>kay</code> ( <code>sudo -l</code> sin credenciales válidas, búsqueda de binarios SUID, cron jobs y kernel) se identificó el binario <code>/usr/bin/pkexec</code> con bit SUID activo, perteneciente al paquete <code>policykit-1</code> versión <code>0.105-26ubuntu1.3</code> . Esta versión es vulnerable a <b>CVE-2021-4034 (“PwnKit”)</b> , que permite escalar privilegios locales a <code>root</code> sin necesidad de credenciales. <b>Estado: explotación en curso.</b> Se intentó descargar un exploit público precompilado directamente desde la máquina víctima, pero esta no posee salida a Internet (timeout de conexión hacia GitHub), por lo que quedó pendiente servir el binario desde la máquina atacante mediante un servidor HTTP local dentro de la red de la VPN de THM. |
| Componente afectado           | Binario SUID <code>/usr/bin/pkexec</code> (paquete <code>policykit-1</code> ).                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                  |
| Categoría (OWASP / CWE)       | CWE-78 (OS Command Injection) / CWE-250 (Execution with Unnecessary Privileges).                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                |
| CVE (si aplica)               | CVE-2021-4034 (PwnKit).                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                         |

|                               |                                                                                                                      |                                                                                                                                                                                                                                      |
|-------------------------------|----------------------------------------------------------------------------------------------------------------------|--------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| CVSS estimado                 | ☒ Crítico                                                                                                            |                                                                                                                                                                                                                                      |
| Evidencia (captura / comando) | <code>find / -perm -4000 -type f, pkexec --version, dpkg -l   grep policykit</code> . Evidencia en evidencias/post/. |                                                                                                                                                                                                                                      |
| Herramienta utilizada         | uti-                                                                                                                 | find, pkexec, dpkg, PwnKit PoC (ly4k/PwnKit).                                                                                                                                                                                        |
| Impacto en la Tríada CIA      | ☒ Confidencialidad                                                                                                   | ☒ Integridad ☒ Disponibilidad                                                                                                                                                                                                        |
| Salvaguarda propuesta         | prop-                                                                                                                | Actualizar <code>policykit-1</code> a una versión parchada (posterior a la corrección de CVE-2021-4034), aplicar los parches de seguridad del sistema operativo de forma regular y auditar periódicamente los binarios con bit SUID. |
| Riesgo residual tras aplicar  | ☒ Bajo                                                                                                               |                                                                                                                                                                                                                                      |

### 3.4. Resumen ejecutivo de hallazgos

| Severidad    | Cantidad | ID de hallazgos |
|--------------|----------|-----------------|
| Crítico      | 1        | H-04            |
| Alto         | 1        | H-03            |
| Medio        | 1        | H-02            |
| Bajo         | 1        | H-01            |
| <b>Total</b> | 4        |                 |

**Conclusión ejecutiva:** la máquina objetivo presentó una cadena de ataque completa, desde el reconocimiento de servicios hasta la identificación de un vector crítico de escalada a `root` (PwnKit), cuya explotación quedó en curso al cierre de este informe por una limitación de conectividad del entorno de laboratorio y no por una mitigación real de la vulnerabilidad. La causa raíz predominante es la falta de actualización de paquetes del sistema operativo, sumada a una política débil de credenciales y a la exposición innecesaria de servicios.

### 3.5. Post-pentesting: Recomendaciones

#### Recomendaciones técnicas (parches y configuraciones)

Priorizadas por criticidad:

1. **(Crítico)** Actualizar `policykit-1` a una versión no vulnerable a CVE-2021-4034 en todos los hosts Linux (H-04).
2. **(Alto)** Imponer políticas de contraseñas robustas y desactivar la autenticación por contraseña en SSH a favor de claves; implementar `fail2ban` (H-03).
3. **(Medio)** Deshabilitar sesiones nulas y limitar el listado anónimo de recursos Samba (H-

02).

4. **(Bajo)** Reducir la superficie de ataque cerrando servicios no esenciales, en particular AJP13 (H-01).

#### Recomendaciones administrativas (políticas y procesos)

- Establecer un proceso formal de gestión de parches (patch management) con ventanas de actualización periódicas.
- Definir una política de contraseñas corporativa y un gestor de secretos para credenciales de servicio.
- Realizar auditorías de seguridad y pentests de forma regular.
- Mantener un inventario de activos y servicios expuestos.

## 4. PARTE III: PROTOCOLO DE CONTINGENCIA

#### Escenario de falla

La explotación de CVE-2021-4034 (PwnKit) sobre un sistema de producción permitiría a un atacante local o remoto con acceso inicial de bajo privilegio escalar a **root** de forma inmediata y sin autenticación adicional, comprometiendo totalmente el host.

#### Impacto sobre la continuidad del negocio

Un compromiso de **root** en un servidor de INSECUR S.A. afectaría la confidencialidad, integridad y disponibilidad de todos los servicios alojados en ese host (datos, configuraciones, otros servicios dependientes). El tiempo de afectación dependería de la detección y de la existencia de respaldos; se estima entre 1 y 4 horas hasta la restauración si se cuenta con backups y procedimientos definidos.

#### Plan de respuesta

1. **Activación:** detección mediante monitoreo (alertas de escalada de privilegios, logs de `auth.log`, EDR/IDS).
2. **Contención (primeros 15 minutos):** aislar el host afectado de la red, revocar sesiones activas sospechosas, preservar evidencia (logs, memoria).
3. **Recuperación:** aplicar el parche de `policykit-1`, restaurar el servicio desde un backup limpio si hubo manipulación, rotar credenciales comprometidas.
4. **Comunicación:** notificar a la dirección de TI y al responsable de seguridad; según el impacto, a clientes y autoridades regulatorias.
5. **Post-mortem:** documentar el incidente, la causa raíz y las lecciones aprendidas; actualizar la línea base de hardening.

**RTO y RPO estimados****RTO** (Recovery Time Objective): 4 horas.**RPO** (Recovery Point Objective): 24 horas (último respaldo diario).

## 5. Anexos

**Anexo A — Bitácora de comandos**

Archivos en el branch: `bitacora/`. Los comandos fueron depurados de credenciales/secretos antes de su publicación.

**Anexo B — Capturas de pantalla**

Carpeta `evidencias/` con subcarpetas por fase: `evidencias/{reconocimiento,escaneo,explotacion,post}`  
*Pendiente de completar con las capturas correspondientes a cada hallazgo (H-01 a H-04).*

**Anexo C — Hashes de las flags obtenidas**

*Pendiente: una vez confirmada la escalada a `root` vía `PwnKit`, incluir aquí el hash SHA-256 de la flag obtenida:*

```
1 # Formato: flag_id  sha256_hash
2 H-04 (root.txt)  <pendiente>
```

**Anexo D — Declaración ética firmada**

Declaro que todas las actividades se realizaron dentro del alcance autorizado, en entornos controlados y con fines exclusivamente académicos.

\_\_\_\_\_  
 Firma del estudiante — Exequiel Caliri (DNI 44.058.433)      Fecha \_\_\_\_\_

## 6. Fuentes y bibliografía

- TryHackMe. *Pentesting Fundamentals*: [sala oficial](#)
- TryHackMe. *Basic Pentesting*: [sala oficial](#)
- TryHackMe. *Kenobi*: [sala oficial](#)
- OWASP Foundation. *Web Security Testing Guide (WSTG)*: [sitio oficial](#)
- PTES. *Penetration Testing Execution Standard*: [sitio oficial](#)
- NIST (2008). *Technical Guide to Information Security Testing and Assessment (SP 800-115)*.
- CVE-2021-4034 (PwnKit) — Qualys Security Advisory.
- Chicano Tejada, E. (2023). *Auditoría de seguridad informática. IFCT0109* (2.<sup>a</sup> ed.). IC Editorial — eLibro.
- White, A. & Clark, B. (2017). *BTFM: Blue Team Field Manual*. CreateSpace Independent Publishing Platform.